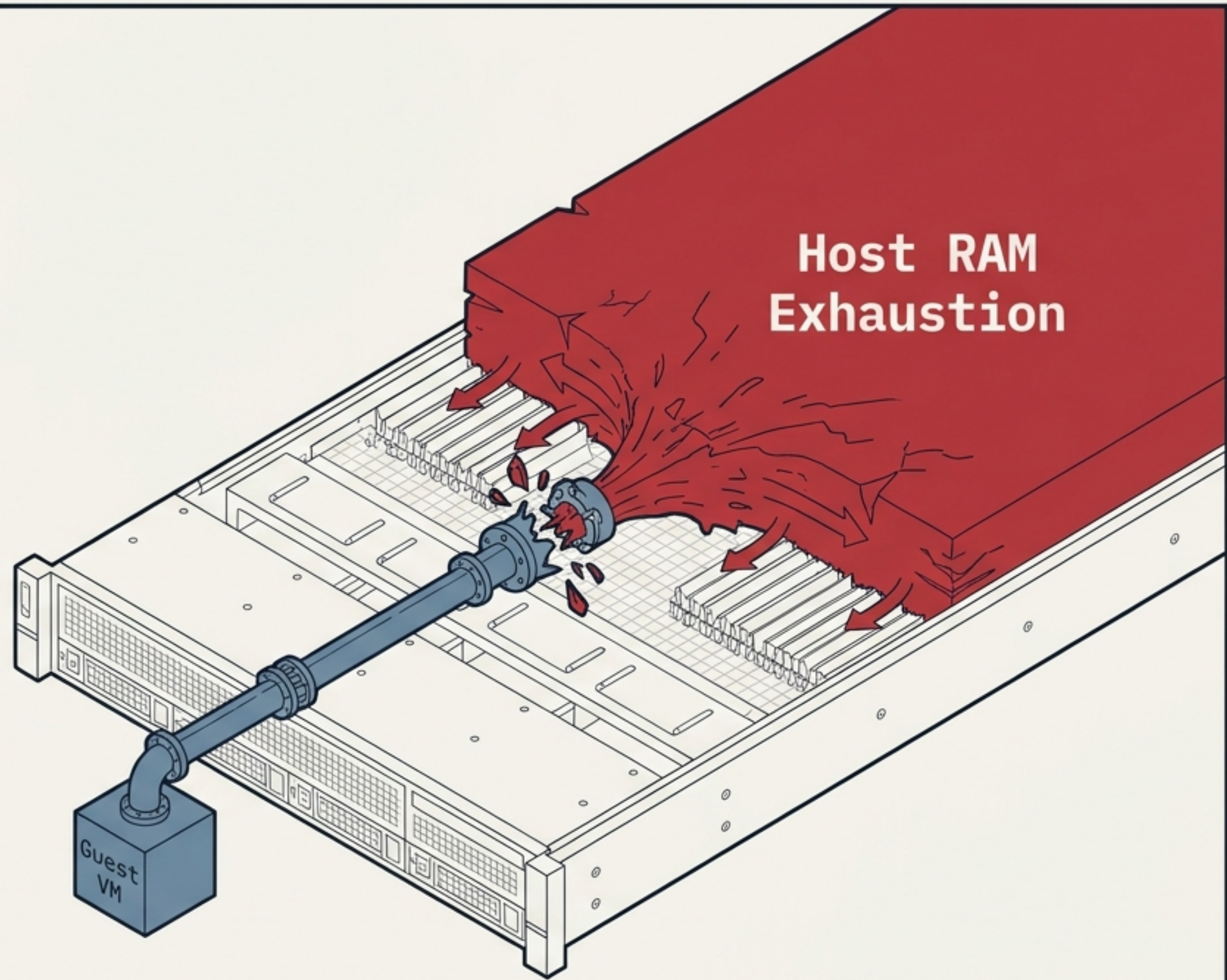


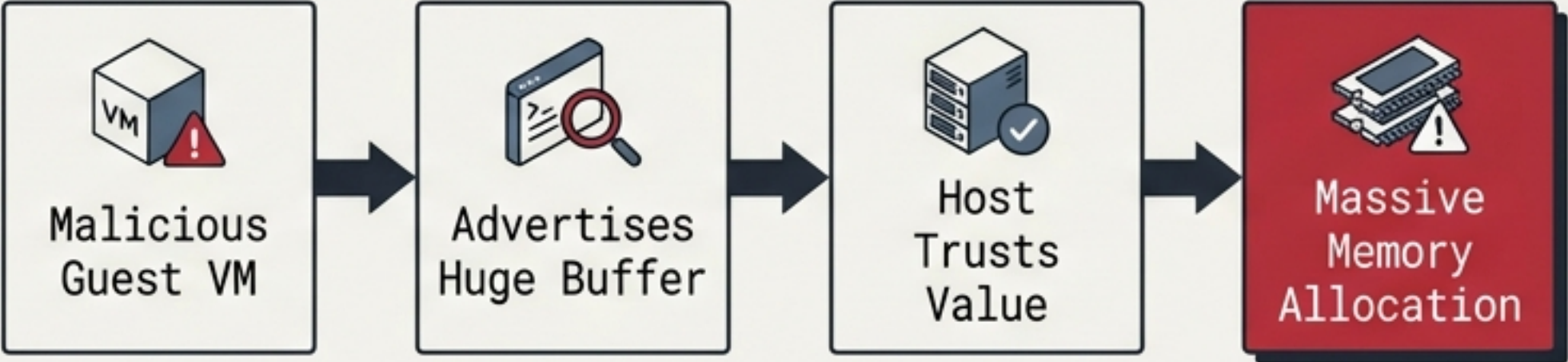
VirtIO VSOCK Resource Exhaustion

Analysis of CVE-2026-23086
and the anatomy of host
memory starvation.

A trust flaw in Linux
kernel networking
allows a single,
unprivileged guest VM
to consume tens of
gigabytes of host RAM,
triggering severe
denial-of-service
conditions.



Threat Intelligence Profile: CVE-2026-23086

Identity & Context		CIA Triad Impact	
Vulnerability: Resource Exhaustion (CWE-770)		Confidentiality: None	
Component: Linux Kernel		Integrity: None	
File: net/vmw_vsock/virtio_transport_common.c		Availability: High	
Severity: Medium		Memory Exhaustion / Potential OOM	
MITRE ATT&CK Mapping		Impact Vector Chain	
T1499: Endpoint Denial of Service			
T1496: Resource Hijacking			
T0814: Denial of Service			

The 57GB Proof-of-Concept

Baseline: Unpatched Ubuntu Host, 64 GB Total System Memory.

Attack Parameters

- ✓ - 32 concurrent VSOCK connections.
- ✓ - 2 GB credit requested per connection.
- ✓ - Continuous slow reading from the guest.



Catastrophic Result: Host Slab Memory spiked from a baseline of 0.5 GB to 57 GB, nearly exhausting all available physical RAM and triggering out-of-memory (OOM) instability.

0.5 GB
Slab memory ➤

Normal State

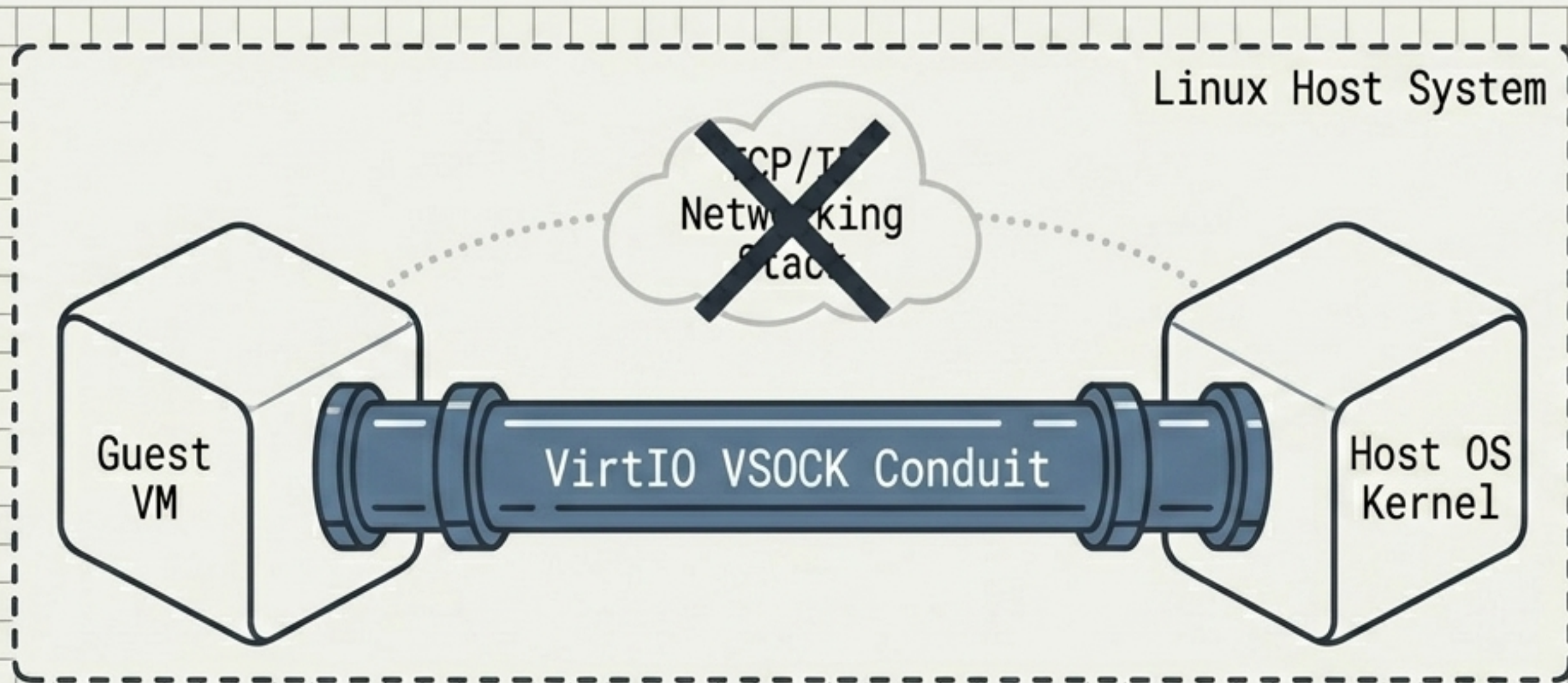
64 GB
RAM MODULE

Under Attack

64 GB
RAM MODULE

◀ 57 GB
Slab memory
exhausted

The Architecture of VirtIO VSOCK



Definition

Virtual Socket Communication.

Purpose

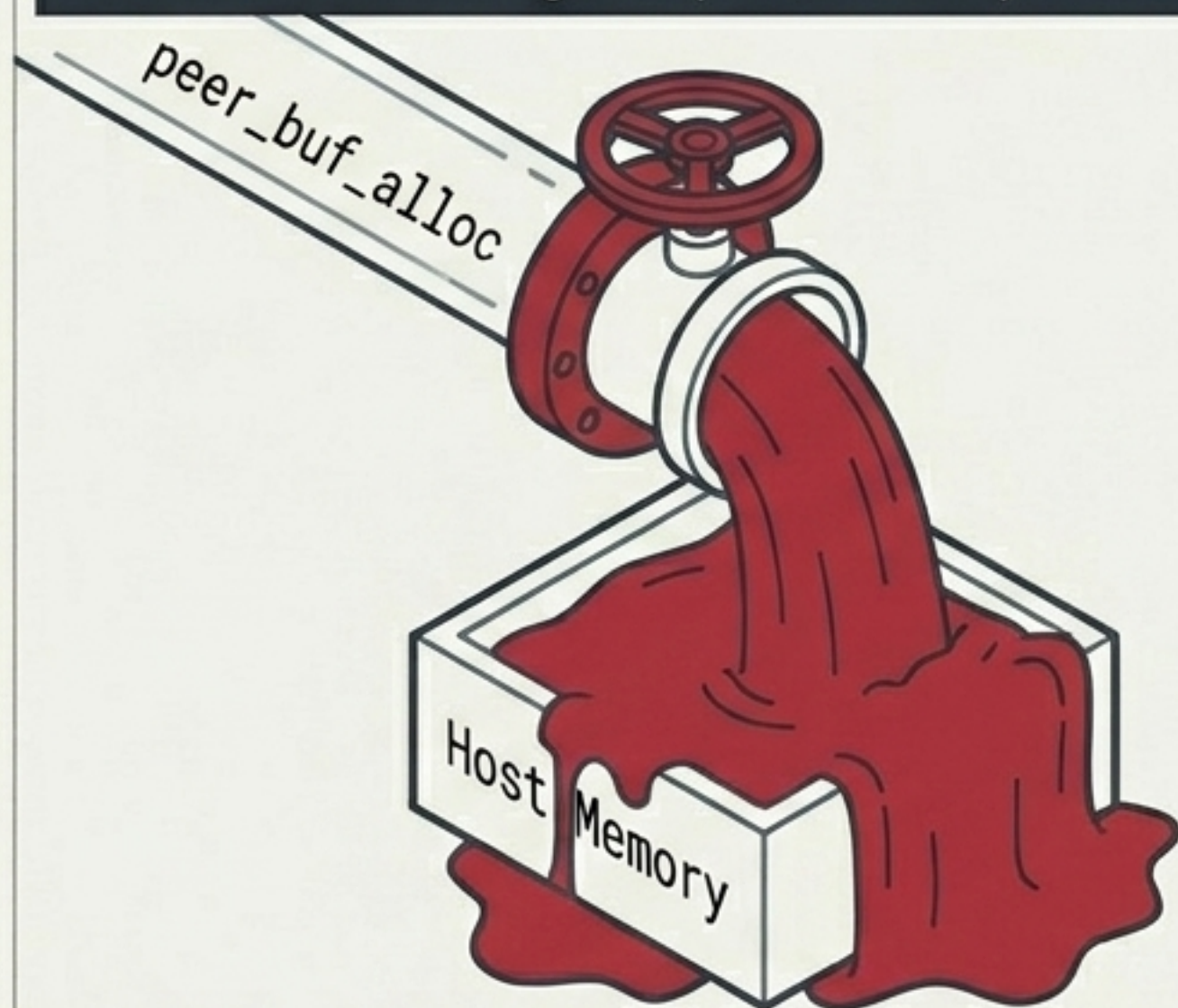
Facilitates high-speed, direct communication between a Guest VM and the Host System.

Key Characteristic

Entirely bypasses the traditional TCP/IP networking stack. Standard network firewalls and remote limits do not apply to this conduit.

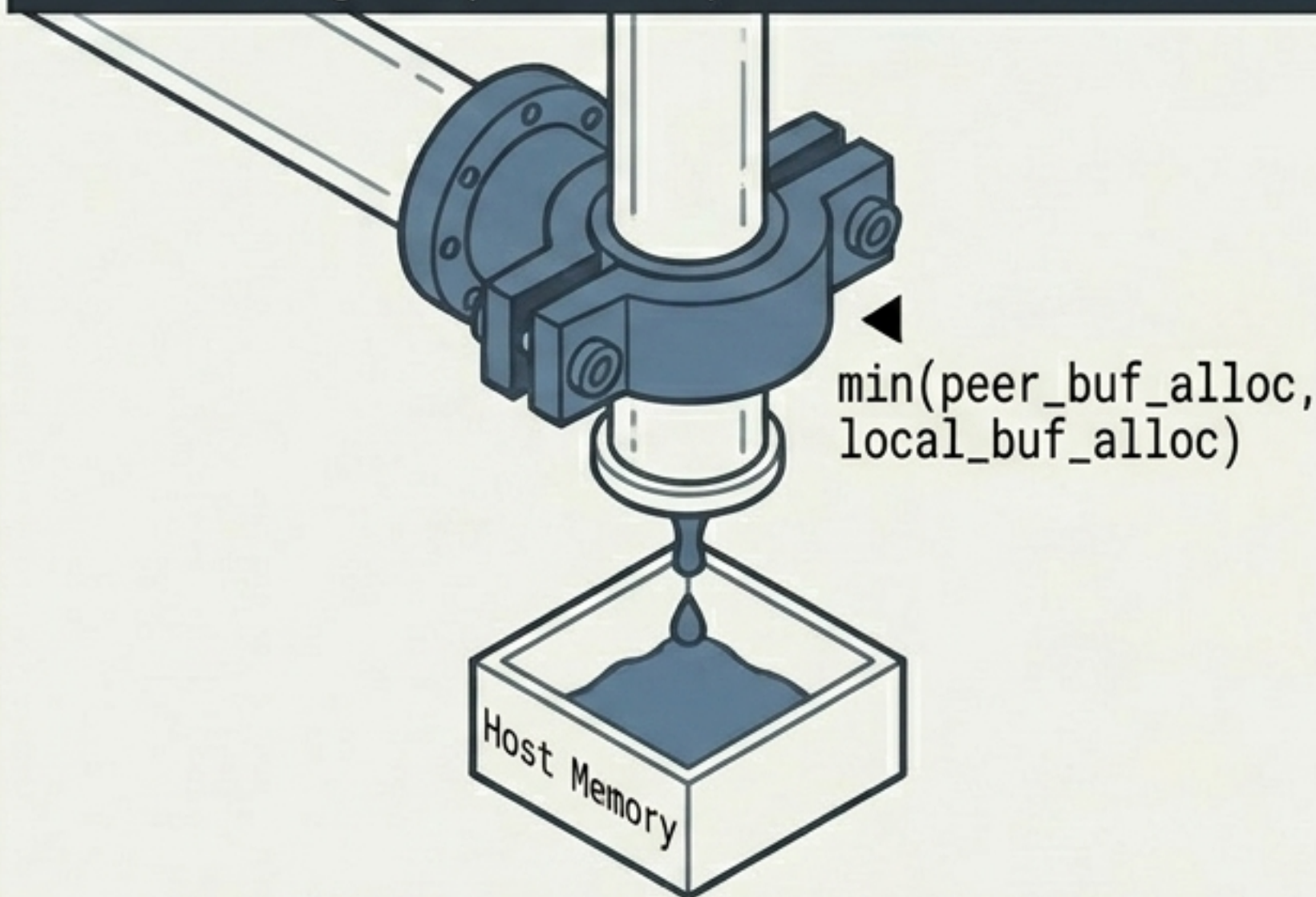
The Root Cause: Unregulated Trust Over Host Memory

Vulnerable Logic (The Flaw)



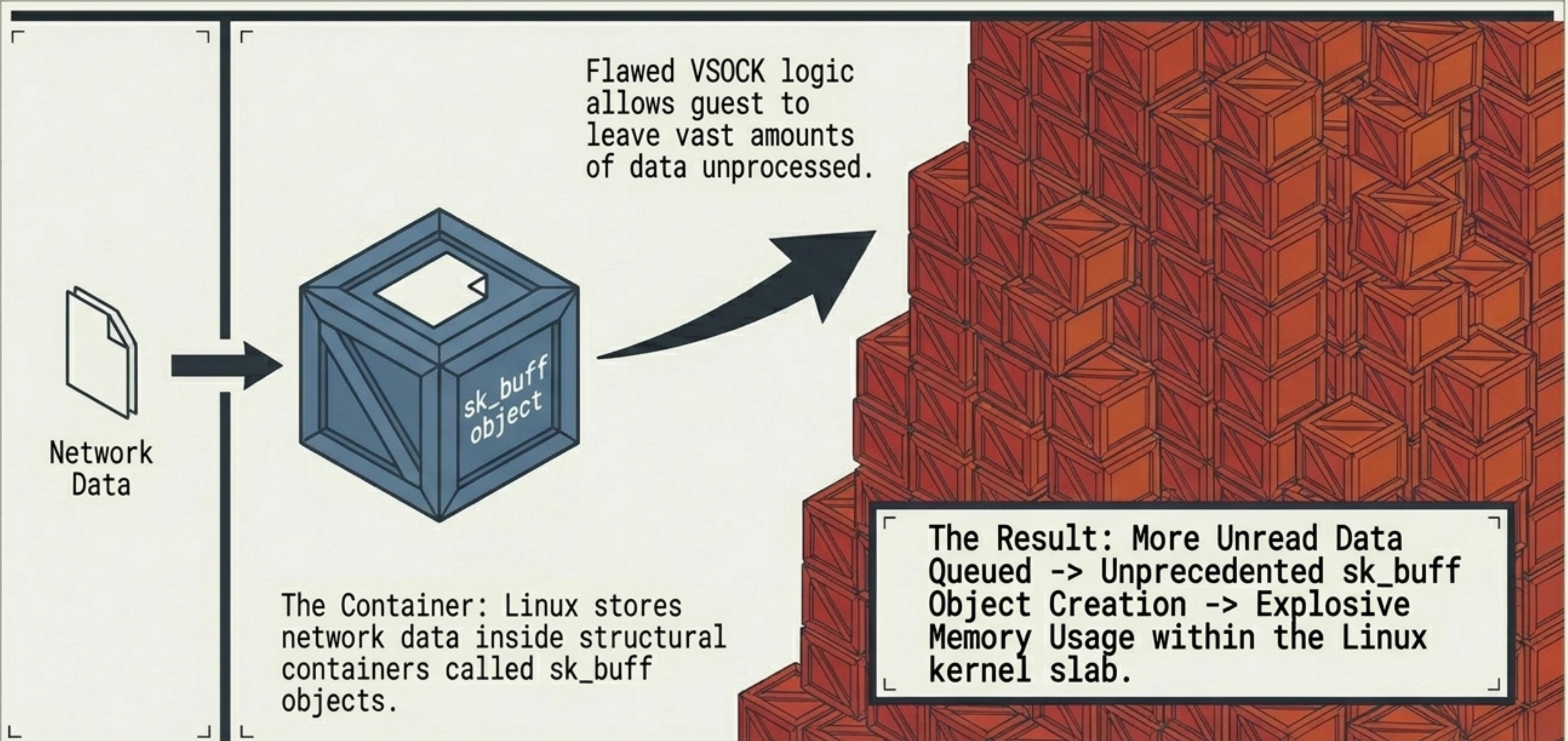
The host derives TX credits directly from the remote peer's advertised buffer size. The remote guest entirely controls host memory allocation.

Secure Logic (The Fix)

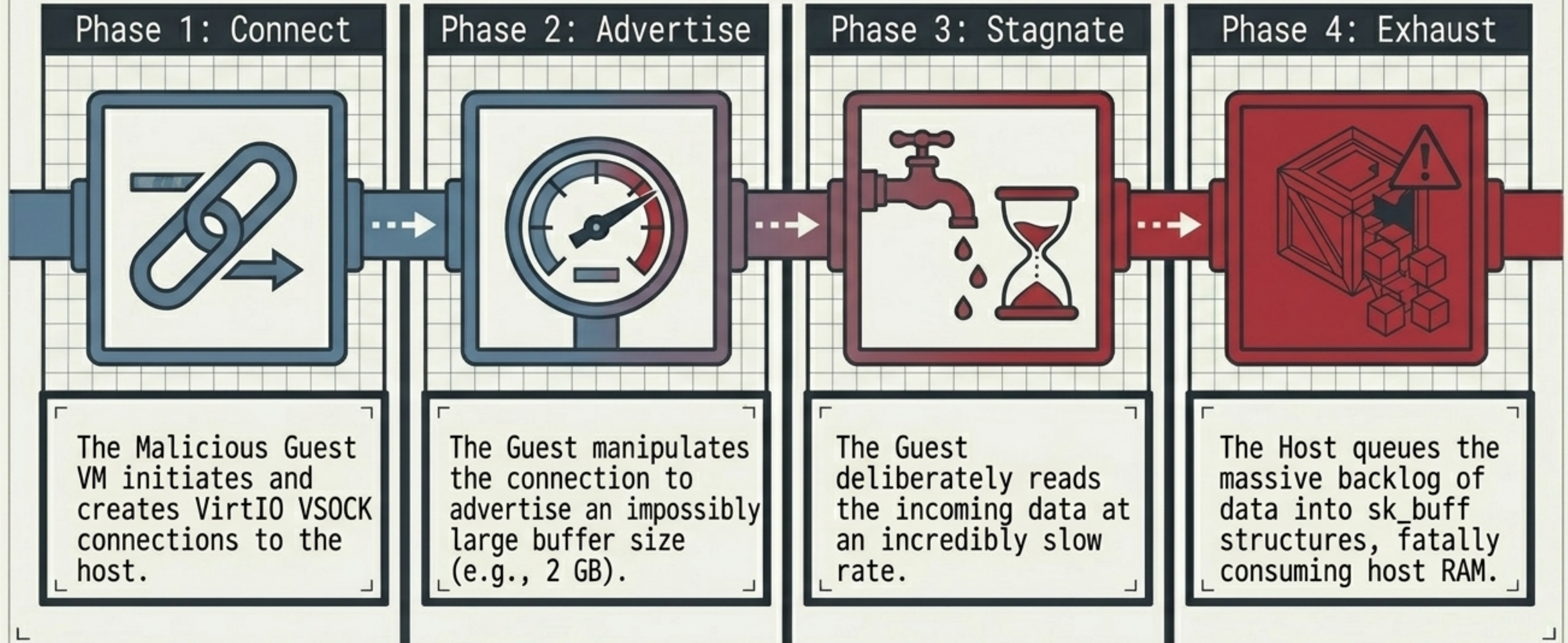


The host applies a strict regulatory function. Allocations are clamped to strictly enforced local host limits.

The Amplification Engine: sk_buff Accumulation



Execution Pathway of the Exploit



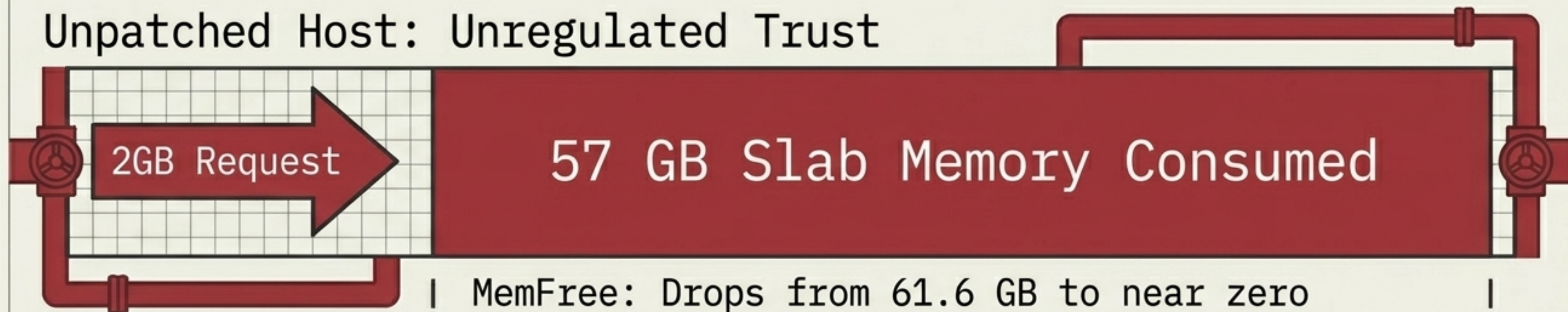
Attack Prerequisite Analysis

Once standard guest access is achieved, exploitation is trivial and autonomous.

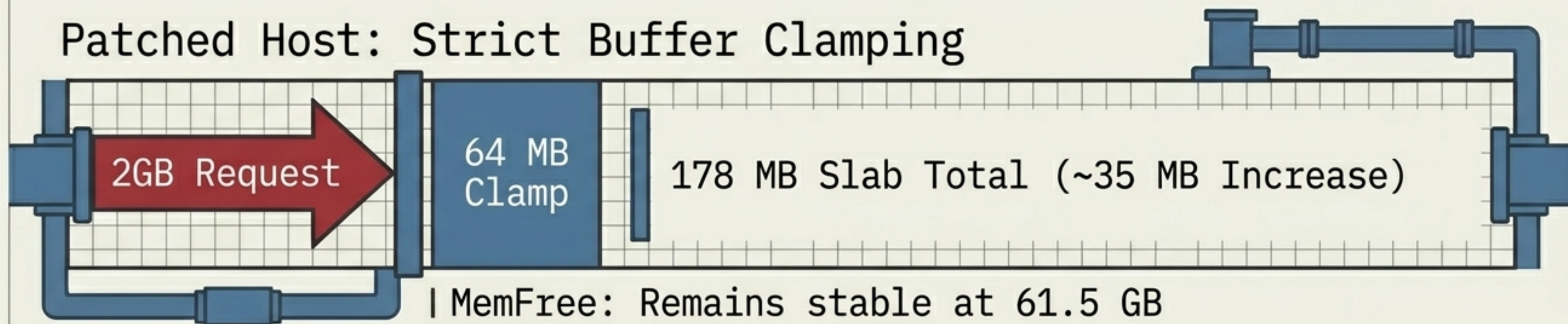
Required to Exploit		NOT Required	
✓	Access to a Guest VM on the host	✗	Root or administrative access on the host
✓	VirtIO VSOCK actively enabled	✗	Physical access to the server
✓	Standard privileges to create network connections	✗	User interaction or social engineering

The Remediation Reality

Unpatched Host: Unregulated Trust



Patched Host: Strict Buffer Clamping



The Defense Playbook

DETECT (Indicators)

-  - Monitor for sudden, massive Slab memory growth.
-  - Watch for high SUnreclaim usage.
-  - Look for unexpected VSOCK traffic and anomalous QEMU memory expansion.

Standard Linux Tooling:

```
free -m | slabtop |  
vmstat | top
```

MITIGATE (Controls)

-  - Restrict unnecessary guest VM access to sensitive hosts.
-  - Monitor internal VSOCK activity boundaries.
-  **CRUCIAL:** Limit QEMU resource boundaries using Linux cgroups.
-  - Enable strict memory monitoring alerts.

REMEDiate (Patching)

Apply the fixed Linux Kernel versions immediately.

Validated Secure Kernels:

6.1.162+ 	6.6.122+ 
6.12.68+ 	6.18.8+ 
6.19+ 	